

etc. Any user who then clicks on such a link is then attacked.

Taking an example from WebGoat. What we have here is a small goods purchase form, the standard deal, which allows you to set quantities, update your cart and purchase using your credit card.

On submitting this form with an “invalid” three digit code we see the following:

As we can see, the invalid value we entered is being directly outputted to the page. Let us take this a step further, and enter some HTML code in the box. We enter a text inside a H1 tag so it will immediately be visible.

We can include a script tag in the input box too, and the page will inject then in the error message, thus executing it.

Now that we know this field is vulnerable, what do we do? We certainly cannot ask users to input our code in a text box!

By inspecting the page, we see that the “three digit access code” field has a name of “field1” in the form. If we could specify a value for that in the URL, we wouldn’t need the user to enter it, as it would be pre-populated, and

It is always a good practice to validate all input on the server side. XSS can occur when unvalidated user input is used in an HTTP response. In a reflected XSS attack, an attacker can craft a URL with the attack script and post it to another website, email it, or otherwise get a victim to click on it.

Shopping Cart

Shopping Cart Items -- To Buy Now	Price	Quantity	Total
Studio RTA - Laptop/Reading Cart with Tilting Surface - Cherry	69.99	1	\$69.99
Dynex - Traditional Notebook Case	27.99	1	\$27.99
Hewlett-Packard - Pavilion Notebook with Intel Centrino	1599.99	1	\$1599.99
3 - Year Performance Service Plan \$2000 and Over	299.99	1	\$299.99

The total charged to your credit card: \$1997.96

Update Cart

Enter your credit card number:

Enter your three digit access code:

Purchase

It is always a good practice to validate all input on the server side. XSS can occur when unvalidated user input is used in an HTTP response. In a reflected XSS attack, an attacker can craft a URL with the attack script and post it to another website, email it, or otherwise get a victim to click on it.

* Whoops! You entered 1111 instead of your three digit code. Please try again.

Shopping Cart

Shopping Cart Items -- To Buy Now	Price	Quantity	Total
Studio RTA - Laptop/Reading Cart with Tilting Surface - Cherry	69.99	1	\$69.99
Dynex - Traditional Notebook Case	27.99	1	\$27.99
Hewlett-Packard - Pavilion Notebook with Intel Centrino	1599.99	1	\$1599.99
3 - Year Performance Service Plan \$1000 and Over	299.99	1	\$299.99

The total charged to your credit card: \$1997.96

Update Cart

Enter your credit card number:

Enter your three digit access code:

Purchase